Contents

Volume 01 — Introduction & Foundations **1**
Lecture T01: Course Welcome 1
Lecture T48: Introduction — Part 01 2
Lecture T03: Introduction — Part 02 4
Lecture T04: Introduction — Part 03 6
Lecture T05: Foundations — Part 01 7
Lecture T06: Foundations — Part 02 9
Lecture T07: Foundations — Part 03 10

Volume 01 — Introduction & Foundations

Cyber Security and Privacy · NPTEL 106106248 · Prof. Saji K. Mathew **notes-3** — concept exam notes (definitions & what things do). Breadth over lab depth.

Lecture T01: Course Welcome

Learning focus

- State why the course treats the cyber world as having a bright side and a dark side.
- Explain why cybersecurity is a management and governance issue, not a technology issue alone.
- Name the two kinds of cybersecurity planning this course will teach: contingency planning and risk-management planning.
- Trace the path from cybersecurity into information privacy, including why data, regulation, and stakeholders matter.

Key terms

Term	Meaning in this lecture
Dark side / dark world	The growing set of attacks, disruptions, and damages that travel with digital adoption
Digital assets	The technology and data on which a business or organization may wholly depend
GRC	Governance, risk, and compliance — the managerial frame for cybersecurity
Twofold role of technology	Technology can be attacked or destroyed; technology is also a source of protection
Contingency planning	Planning that assumes incidents (including ransomware) can happen, then restore and recover
Residual risk	The quantitative or qualitative leftover risk after valuing assets, threats, and probabilities
Risk-management planning	Preventive planning of management action per asset; not an assumption that harm has already occurred

Term	Meaning in this lecture
DPDP	Digital Personal Data Protection Act — India's then-pending privacy law
GDPR	European data-protection regulation, named as a global counterpart to DPDP

Frameworks / formulas

- **GRC triad (managerial):** governance + risk + compliance.
- **Two-track planning:** contingency (reactive recovery after incidents) versus risk management (preventive residual-risk action).
- **Course arc:** awareness → GRC/planning/standards → protection technologies (including cryptography and a guest practitioner) → information privacy (fundamentals, stakeholders, GDPR/DPDP, managerial–economic–strategy view).

Distinctions

- Technology's usefulness (ease, efficiency, effectiveness) is not the whole story; **adoption and dark-world challenges grow together**.
- This is **not** a technology-only course. Cybersecurity is also administration: GRC.
- Contingency planning **assumes something can already have gone wrong**; risk-management planning **does not** assume an incident has happened — it is preventive.
- Privacy is not a side topic bolted on at the end: **data is often what is at risk**, and cybersecurity technology is also a tool for protecting information privacy.

Exam lines

- Course thesis: digital technology eases work **and** creates a dark side that can collapse a digitally dependent organization.
- Audience: practicing managers and cybersecurity professionals; anyone who uses or is responsible for technology.
- Managerial core: GRC; planning of two kinds (contingency / residual-risk); standards.
- Technology: both target and protection; later, cryptography plus an industry guest.
- Privacy track: data value → fundamentals of privacy → DPDP, GDPR, Supreme Court right to privacy → stakeholders and strategy.

Lecture T48: Introduction — Part 01

Learning focus

- Give working meanings of **cybersecurity** and **privacy**, and say why their intersection matters.
- Explain why a manager, not only an IT person, should treat cybersecurity as a live concern.

- Distinguish **phishing**, **social engineering**, and **spear phishing** using the instructor's own mailbox examples.
- Contrast **ransomware** with **denial of service**, and say why healthcare data (AIIMS, HIPAA) is treated as especially sensitive.

Key terms

Term	Meaning in this lecture
Data / vulnerability / unauthorized access	The three student keywords the instructor keeps for "cybersecurity"
Privacy (working sense)	Me and my data; I choose what to disclose; distinct from a system-level security layer
Phishing	Fraudulent mail/message; everyday junk asking for bank or personal details
Social engineering	Collecting background on who is who so a fake mail is believable
Spear phishing	Specific, social-engineering-based phishing with a background study; higher response chance
Ransomware	Attacker encrypts / takes control of a machine and demands money for the key
Denial of service	Named only as **different** from ransomware; a DoS case is promised later
POS	Point of sale — checkout/payment machines in retail; if they stop, automated shops stop
HIPAA	US healthcare-data regulation, cited to explain why health records are treated as super sensitive

Frameworks / formulas

- **Check-the-sender / check-the-URL hygiene:** suspicious professional mail → inspect sender domain; sign-in SMS → inspect the real website address, not the lookalike page.
- **Bright side / dark side of digital:** more digitization, more reported attacks; cybersecurity is the dark-side concern.
- **Pay-versus-refuse ransomware:** per-hour business loss often dwarfs ransom (Kaseya pattern); refusal is illustrated only where systems were already obsolete (Chennai Corporation).

Distinctions

- Cybersecurity and privacy are **two terms in the title**; their **intersection** is part of the course, not a merge of the two words.
- A mail that does **not** ask for passwords can still be spear phishing; **tone and domain** can be the giveaway.
- Everyday phishing is obvious; **spear phishing** is dangerous because it impersonates someone inside your circle after reconnaissance.

- **DoS ≠ ransomware.** Ransomware is control + encryption + payment to release.
- Healthcare data is not "just another database": embarrassment, organizational harm, and dedicated law (HIPAA) explain why AIIMS was a national story.
- Paying ransom is common for **critical operations**; Chennai Corporation is taught as an **exception**, not the default.

Exam lines

- Managers should care because attacks already arrive as official-looking mail, fake bank pages, POS shutdowns, and hospital-server takeovers.
- Keep: data, vulnerability, unauthorized access; privacy as control over disclosure; intersection of the two.
- Spear phishing = phishing + social engineering + target-specific background.
- Ransomware lock-and-key analogy; Kaseya $70M; Chennai refusal on Windows 8.
- AIIMS + HIPAA: health data is super sensitive.
- EY 91% / CEO priority: this is not a niche IT problem.

Lecture T03: Introduction — Part 02

Learning focus

- Explain how internet-connected cars, IoT sensors, and drones move cyber risk from "lost data" to **halted systems and harm to people**.
- State the instructor's basic principle: **any device connected to the internet is not safe**.
- List the **units** cybersecurity affects: individuals, organizations, society, and government — including government's dual role.
- Articulate technology's **triple role**: source of threat, asset to protect, and defense weapon.

Key terms

Term	Meaning in this lecture
Smart connected devices / IoT	Devices with processing that connect to the internet and transmit data, not only PCs
"Any internet-connected device is not safe"	The basic principle stated for IoT / connected systems
Manufacturing 4.0	New generation of digital / smart manufacturing — taught as the bright side of the same sensors
Information security vs cybersecurity	Older focus on data in IS; cybersecurity is the more recent, wider term

Term	Meaning in this lecture
Scope widening	From information → infrastructure → people; damage to people is real
Units	Individuals, organizations, society, government — all have cyber challenges
Government's dual concern	Protect own systems/data **and** regulate for citizen welfare
Privacy as close cousin	Privacy / data protection interrelated with cybersecurity
Triple role of technology	Threat source, asset, defense weapon

Frameworks / formulas

- **Cars analogy:** do not ban the useful technology; **increase safety** (same logic as not abandoning digital tools).
- **Trade of privileges:** refusing WhatsApp / TV / social media can reduce exposure, but you **lose** digital privileges; most people will not take that path.
- **Triple-role test:** whenever "technology" is mentioned in a cybersecurity sentence, name whether it is the **attack tool**, the **asset**, or the **control**.

Distinctions

- Losing data on a computer is **not** the ceiling of harm; connected cars, refineries, and drones show **halted operations and harm to people**.
- Analog wired sensors were hard to manipulate remotely; **digital + internet** is what opens unauthorized access.
- Cybersecurity is **not** just a new name for information security; **people and infrastructure** are in scope.
- A hacked **IT company** (Twitter, TCS) is taught as **embarrassment and public explanation**, including the outsourcing excuse — not as proof that "tech firms cannot be hacked."
- "Cybersecurity technologies" **does not automatically mean defensive products**.
- Government is both a **potential victim** (Aadhaar-scale data) and a **regulator**; privacy will be discussed with a claim of party-neutrality.

Exam lines

- Connected cars + ICAT: cybersecurity testing because lives can be destroyed, not only data lost.
- Saudi refinery 16 Sep 2019, 4 a.m., drones; Citibank/ERP as "if IT stops, the organization stops."
- IoT principle: internet-connected ⇒ not safe; false temperature can wreck process control.
- Drones also kill (Soleimani); people are now in the security perimeter.
- Units: individual / organization / society / government; government = own systems + regulation.

- Technology = threat + asset + defense; DoS scripts and firewalls are both "technology."

Lecture T04: Introduction — Part 03

Learning focus

- Define **security** as a state (and a psychological sense) of being safe, then scale it from the individual to the organization.
- Distinguish **information security** from the wider **cybersecurity**, including the ITU 2008 definition and the spelling conventions.
- State the **CIA** triangle as the three elements cybersecurity/information security seeks to ensure, and quote the Whitman and Mattord definition of information security.
- Explain why this course is **management and governance first**, with technology in a threefold role, and preview GRC, two kinds of planning, Target/Sony, and privacy regulation.

Key terms

Term	Meaning in this lecture
Security (general)	A state of being safe / feeling secure; also psychological / emotional
Information security	Protect information as an asset (data, databases, systems that use/store/transmit it)
Cybersecurity	Information security **plus** individuals (and the networked world's users and systems); ITU 2008 is all-inclusive
Cybernetics	Greek origin: steersman / control; source of the prefix "cyber"
CIA triangle	Confidentiality, integrity, availability of information
False positive / false negative	Wrongly admitting someone without right, or wrongly denying someone with right (gate analogy)
Zero trust	"Trust none" — reduce dependence on human credibility
Contingency vs risk planning	Reactive restoration after failure vs preventive treatment of what can go wrong
Passive vs active defense	Walls / protection vs going beyond, including "shooting" / offending attackers (legal issues flagged)

Frameworks / formulas

- **Spelling rule:** any of the three written forms, **one convention per document**.
- **Whitman & Mattord (2018):** protection of information **and its critical elements**, including systems and hardware that **use, store, and transmit** that information.
- **ITU (2008):** long list (tools, policies, concepts, safeguards, guidelines, risk-management approaches, actions, training, best practices, assurance, technologies) — taught as **breadth**, not as a definition to memorize word-for-word.

- **Course stack:** foundations / CIA → Target (and Sony as twin shock) → GRC/ISO → contingency + risk → policy → crypto & defense (guest) → privacy regulation (NA, EU, India).

Distinctions

- Feeling secure is real, but organizational security is about **authorized vs unauthorized** entry and **verification**, including gate errors.
- **Information security ⊂ cybersecurity.** Adding "cyber" is not a synonym swap; **people** (cyber crime, drones, safety) enter the scope.
- US vs European **spelling** is a consistency issue, not a meaning issue.
- This course studies **what encryption does**, not **how the algorithms work**.
- Firewalls/IDS are **an** element; without **administration, standards, and national regulation**, investment incentives collapse.
- Contingency planning is **firefighting after failure**; risk management is **preventive** and does **not** assume the incident has already happened.
- Active defense is **not** a casual suggestion — **legal sides** matter.

Exam lines

- Security = state of safety (and a feeling); orgs protect physical + informational assets; gates implement authorized access with possible false +/−.
- Cyber from cybernetics (control / steersman) → internet-connected world.
- Cybersecurity = IS + individuals; ITU 2008 is deliberately all-inclusive.
- CIA is the purpose of information security management; Whitman–Mattord 2018 is the textbook definition.
- Managerial course: GRC, two planning types, policy, Target/Sony cases, guest on protection tech, then privacy law (GDPR and India).
- Technology's threefold role remains in force; "cybersecurity technologies" ≠ only products you buy to defend.

Lecture T05: Foundations — Part 01

Learning focus

- Read information security as three constituents (**network; computer and data; management**) with **policy** at the intersection, mapped onto storage, processing, and transmission.
- Use the **McCumber cube** (NSTISSC / John McCumber) so that no cell of cybersecurity is missed.
- Define **confidentiality, integrity, and availability** the way this lecture defines them, with the Alice–Bob–Eve, CV, and IRCTC examples.
- Recall CIA as the **purpose** of information security even if everything else is forgotten.

Key terms

Term	Meaning in this lecture
Policy (in the diagram)	Intersection/reference that guides security practice and investment decisions
Storage / processing / transmission	The three computing aspects that must be secured
CIA triangle	Purpose of information security: confidentiality, integrity, availability
McCumber cube	3×3×3 model: computing × CIA × (policy, education, technology)
Confidentiality	Intended recipient only (A→B, not C); data collector's duty given consent
Integrity	Data arrives intact: whole, unmanipulated; includes subject's ability to keep it complete/correct
Availability	Intended party can access when needed, as per contract; other side of confidentiality
Redundancy	Extra systems so availability survives a failure
Nines	Contractual availability target (e.g. 99.9999…); more nines cost more

Frameworks / formulas

- **McCumber cells = 3 × 3 × 3.** A manager's checklist: for each combination of (storage|processing|transmission) × (C|I|A), are policy, education, **and** technology in place?
- **Availability vs cost:** higher contracted nines ⇒ more redundancy ⇒ higher cost; **100% ≈ unbounded cost**.
- **Consent chain:** data subject ↔ collector/processor; confidentiality = honour that contract about **who** may see the data.

Distinctions

- Information security is **part of** cybersecurity but, in this foundations block, the two terms are used **synonymously** while CIA is taught.
- Policy is not a poster on the wall: it is the **decision reference** for **how much to invest** and **how much to leave unprotected**.
- Confidentiality is **not** "hide everything"; it is **intended vs unintended** readers, including after interception (encryption).
- Integrity is **not** only "no hacker edited it"; missing updates and **wrong data entry** (DOB) are integrity failures, tied to **access rights of the subject**.
- Availability is **the other side of confidentiality**, not a third unrelated slogan. Unauthorized people must **not** see it; authorized people **must** be able to.
- Reliability engineering's contribution here is specifically **redundancy**, not a new CIA letter.

Exam lines

- Three constituents of IS: network, computer/data, management; **policy** at the centre; map onto store / process / transmit.
- McCumber cube: computing × CIA × (policy, education, technology); do not miss a cell.
- Confidentiality: Alice–Bob–Eve; Aadhaar/consent; classification; encryption so intercept ≠ understand.
- Integrity: intact, complete, unaltered; CV and DOB; subject access to correct "my data."
- Availability: IRCTC; redundancy; SLA nines; 100% can be infinitely expensive.
- Midnight recall: cybersecurity does **CIA**.

Lecture T06: Foundations — Part 02

Learning focus

- Sequence **identification → authentication → authorization**, and place **accountability** when incidents happen.
- Explain why confidentiality needs a **credible identity** before access rights can mean anything (gate, Aadhaar, SIM, email).
- Tell the **Target** story (US retail, Thanksgiving/Christmas **2013**, HVAC vendor, POS) without jumping to solutions.
- Separate **technological** from **managerial** vulnerabilities, then show why the case **ties them together** (authorization, turned-off malware tools, false positives, efficiency vs security).

Key terms

Term	Meaning in this lecture
Identification	Creating credible identity (ID card, Aadhaar number, employee ID, account number)
Authentication	Verification that a person is who they **claim** to be (ID shown, fingerprint, password)
Authorization	Predefined **level of access** by role after authentication
Accountability	After an incident, assign **who is responsible** so action can be taken; needs **logs**
Vulnerability	A weakness (unlocked door, unencrypted RAM, vendor over-privilege)
Exploit	Using a known vulnerability; not every vulnerability is exploited
False positive	Benign activity flagged as malicious; eats efficiency; tempts people to disable tools
False negative	Malicious activity not flagged; "very dangerous"
Efficiency–security conflict	Tight controls stall operations (POS queues); bypass is the shortcut

Frameworks / formulas

- **Confidentiality stack:** identify people → authenticate claims → authorize by mapped roles ↔ classified information.
- **Accountability loop:** incident → logs → responsible role → fix the vulnerability (or it repeats).
- **Defense in depth (as it failed at Target):** authorization/configuration **then** malware detect/report/auto-delete **then** (ideally) logging — each layer bypassed or mis-set.
- **Type 1 / type 2:** false positive vs false negative; **no 100% precise** detector.

Distinctions

- Identification **creates** identity; authentication **checks a claim** using that identity. You cannot authenticate well without valid identities (IIT card will not get you a SIM).
- Password leak means authentication **fails open**; that is why MFA is coming later — not taught in depth here.
- Authorization is **not** "are you in the building?"; it is **what this role may touch** (vendor vs POS).
- Accountability is **not** a fourth CIA letter in this talk; it is **incident responsibility** and **logs**.
- Target is **not** "they had no security." They had Pentagon-scale tools (spelled out more in Part 03); **practice, configuration, and bypass** failed.
- Turning off malware tools because of false positives is **managerial**, even when the box is a technical product.
- Do not dump all vendor access into "a tech bug": it is **authorization**, hence **techno-managerial**.

Exam lines

- ID → AuthN → AuthZ, then accountability with logs when incidents happen.
- Aadhaar: hard identification (vendors, number); later biometric authentication.
- Target 2013, US retail, holiday peak, HVAC vendor, unencrypted POS RAM, encrypted transmission, malware tools off, false positives, efficiency vs security, incomplete logging.
- Vulnerability ≠ exploit; unlocked classroom.
- Breach = combination of technical and managerial failures, especially **authorization** plus **disabled monitoring**.

Lecture T07: Foundations — Part 03

Learning focus

- Assess Target's **tangible** and **intangible** impact (money, lawsuits, holiday profit, goodwill, regulation).
- Reconstruct **what really went wrong** despite CIA-agency-grade tools: vendor access, failed segmentation, **RAM scrapers**, ignored alerts.

- Use the **Titanic / Captain Smith** story and **Andrew Grove's** "paranoid" advice as the managerial moral: **do not ignore safety warnings**.
- State the **watershed** regulatory lesson and the provocative industry quote on investing the **bare minimum** and paying fines later.

Key terms

Term	Meaning in this lecture
Tangible impact	Court settlements / fines / payouts on the order of **$100 million**
Intangible impact	Trust, reputation, opportunity cost, **goodwill**, customer switch to rivals
Network segmentation	Isolating third parties from POS — Target **failed** this
RAM scraper	Malware that taps unencrypted card data from POS memory
Watershed moment	Target as a turning point for **how governments frame breach rules**
Paranoid mindset	Grove: doubt the appearance that "everything is fine"; do not ignore warnings
Bare-minimum position	Invest little in security, treat breaches as a cost of fines if the firm can bear them

Frameworks / formulas

- **Impact split:** tangible (lawsuits, insurance, Visa, customer payouts) + intangible (goodwill, −46% holiday profit, regulatory shock).
- **Scale check:** $100M / $72B ≈ "pickpocket" — used to motivate why some boards **under-invest** unless law or competition says otherwise.
- **Captain's rule:** safety warning → **act**; calm appearance is not evidence.
- **Risk-management preview:** ignore / court / signal / informed deferral — **options**, not yet a full treatment.

Distinctions

- **CIA the agency ≠ CIA the triangle.** Target's tools matched intelligence-agency **protection systems**.
- Compliance and expensive tools **do not** equal safety if **vendor authorization, segmentation, and alert handling** fail.
- Credit **unions** ≠ credit **card companies** in this impact story.
- $100M can be **existentially small** for a $72B retailer **and still** be a **national regulatory** event because **people's data** is at stake.
- Bypassing malware reporting is not a clever efficiency hack; it is **Captain Smith**.
- "Paranoid" is taught as a **professional attitude**, not as clinical language.
- Paying fines after the fact is a **possible management position** only where **regulation and competition** allow it; the EU-style comprehensive law changes that calculus.
- Informed risk-taking (have a plan) ≠ **closing your eyes**; the course will return to this under **risk management**.

Exam lines

- Target impact: ~$100M tangible, >90 lawsuits, holiday profit −46%, goodwill / Walmart, government rewrite of breach rules.
- Cause recap: vendor access + failed segmentation + RAM scrapers on unencrypted POS memory + malware reporting **switched off**.
- They had $1.6M tools, CIA-agency-like systems, audits, card-industry standards — **administrative failure** still produced the breach.
- Titanic: ignored iceberg warnings; aviation: protocols work when not bypassed; Grove: paranoid managers survive.
- US lacked one comprehensive cyber/privacy law; EU had one; boards may choose bare-minimum security if fines are not fatal — unless markets punish the signal.
